What happened to PHP?

01 / OVERVIEW | PHP2Shell: an issue in PHP itself, which powers websites

Risk of attack even before login
On October 21, 2026, the PHP development team released fixes for two critical vulnerabilities. Under the right conditions, an unauthenticated attacker could execute unauthorized code on the server.

What is PHP?
A server-side programming language used by WordPress and other systems. It generates pages and processes user input.

CVE-2026-109618
Handling of an out-of-memory condition can leave internal data incomplete; invalid memory operations may lead to code execution.

CVE-2026-109619
Stale internal state involving freed memory may remain and be used in a subsequent request, potentially leading to code execution.

Both have a severity of 9.2 / 10
“Critical” under CVSS v4.0. Whether an attack succeeds also depends on the configuration and settings.

Strengthening the admin password alone does not address the root problem.
TODOROKI / CYBER SECURITY / 2026.10.23

What are the risks?

02 / RISK | The damage depends on PHP's permissions and accessible information

01 Information leakage
Server configuration, credentials and information in accessible databases could be stolen.

02 Website tampering
Rewritten pages or links and fake input forms could also harm users.

03 Service disruption and persistent intrusion
Disrupted processing or malicious files could stop business operations or enable re-entry.

Not just WordPress
PHP's official guidance broadly covers PHP environments processing web requests, including PHP-FPM, Apache mod_php, php-cgi, FrankenPHP and LiteSpeed.

For mod_php in particular, there are demonstrations of an attack succeeding before application code runs. A login screen alone is no assurance.

These are possible consequences, not a claim that every website has already been compromised.
TODOROKI / CYBER SECURITY / 2026.10.23

The fundamental fix: update PHP itself

03 / UPDATE | Check separately from WordPress core and plugin updates

Versions containing these fixes
PHP 8.2: 8.2.35
PHP 8.3: 8.3.36
PHP 8.4: 8.4.27
PHP 8.5: 8.5.12

Use the fixed version above or a later version in the same branch, or a package whose distributor has applied these fixes. Do not judge by the displayed version alone; also check the provider's announcement.

Check → preserve → update → inspect
1. Check the server control panel or provider for PHP use and patch status.
2. Back up files and databases and check compatibility.
3. Update PHP, restart required processes and check for missed updates.
4. Check page display, login behavior, suspicious files and traffic.

Regular support for PHP itself has ended for PHP 8.1 and earlier. Ask the distributor about available fixes and move toward a supported branch.

For shared hosting, ask: “Have these two CVEs been addressed?”
TODOROKI / CYBER SECURITY / 2026.10.23

What if you cannot update?

04 / ACTION | Temporary measures, incident response and steps for ordinary users

Do not assume temporary measures make you safe
Official settings changes can reduce some attack paths, but only updating fully resolves the issue. Consult the administrator and consider restricting access or temporarily stopping affected services.

Do not copy configuration values blindly
Disabling upload progress is a mitigation for specific paths. Changing memory limits can affect availability; assess the entire environment.

If intrusion is suspected, updating is not the end
A fixed version does not remove malicious files already installed. Preserve logs and other evidence, investigate the scope and, if needed, restore from a safe environment and change credentials.

Ordinary users should check official notices
The operator must fix its server. Read service warnings and stop entering information into unusual login or payment screens. Follow announced procedures through the official app or a known official website.

“Displaying normally” alone does not establish safety.
TODOROKI / CYBER SECURITY / 2026.10.23